OPENSEC STUDIO V1.10.10 OFFICIAL RELEASE

Offizielles Illustriertes Handbuch OpenSec Studio

Die Cybersecurity-, Web-Audit- und DevSecOps-Suite für jedermann verständlich erklärt



SCHÖPFER & LEITENDER SOFTWAREARCHITEKT

el saghet

OKTOBER 2026

OpenSec Security Engineering

📚 Inhaltsverzeichnis

1. 📖 **Prolog: Das Große Internet-Dorf**
2. **Kapitel 1:** Erster Flug & Bildschirmanatomie
3. **Kapitel 2:** Das Dashboard-Kontrollzentrum
4. **Kapitel 3:** Der Zollbeamte (HTTP-Interceptor & HTTPS-Tunnel)
5. **Kapitel 4:** Das Bordbuch (HTTP-Historie)
6. **Kapitel 5:** Der magische Kopierer (Nativer Rust-Repeater)
7. **Kapitel 6:** Der Schlüsseltest-Roboter (Intruder)
8. **Kapitel 7:** Der Live-Sicherheitsprüfer (DAST-Scanner & YAML)
9. **Kapitel 8:** Der Türklinken-Prüfer & Schlosser (Portscan & SSH)
10. **Kapitel 9:** Das magische Rezeptbuch (Nuclei-YAML-Vorlagen)
11. **Kapitel 10:** Der Universal-Übersetzer (Decoder)
12. **Kapitel 11:** Der Materialprüfer (SCA-Abhängigkeiten)
13. **Kapitel 12:** Die Schatzkarte (SiteMap & JS-Spider)
14. **Kapitel 13:** Der Spionage-Briefträger (OAST Collaborator)
15. **Kapitel 14:** Die Zeitmaschine & der Richter (Diffing & PCI-DSS)
16. **Kapitel 15:** Die große geheime Enzyklopädie (Offline CVE Feeds)
17. **Kapitel 16:** Der Missionssafe (.opensec-Projekte)
18. **Kapitel 17:** Der Erweiterungsladen (BApp Community Store)
19. **Kapitel 18:** SSL-Zertifikate, 60 Tage Testphase, $30 BTC-Spende & Credits
20. **Kapitel 19:** Die Cloud-Sternenkarte (CloudGraph: CNAPP, Wiz-Engine, DSPM & SIEM)

📖 Prolog: Das Große Internet-Dorf

> **🏘️ Die Metapher von Briefen und Geschäften**
>
> Stellen Sie sich vor, das **Internet** sei ein lebendiges Dorf voller Häuser und Läden:
>
> - **Ihr Webbrowser:** Sie spazieren durch die Straße und fragen nach Waren.
> - **Der Webserver:** Ein Geschäft mit Verkäufern hinter der Theke.
> - **Ein HTTP-Request:** Ein Brief, den Sie absenden: *"Bitte zeigen Sie mir den Katalog"*.
> - **Ein HTTP-Response:** Das Paket, das der Laden mit der Antwort zurücksendet.

Was ist OpenSec Studio?

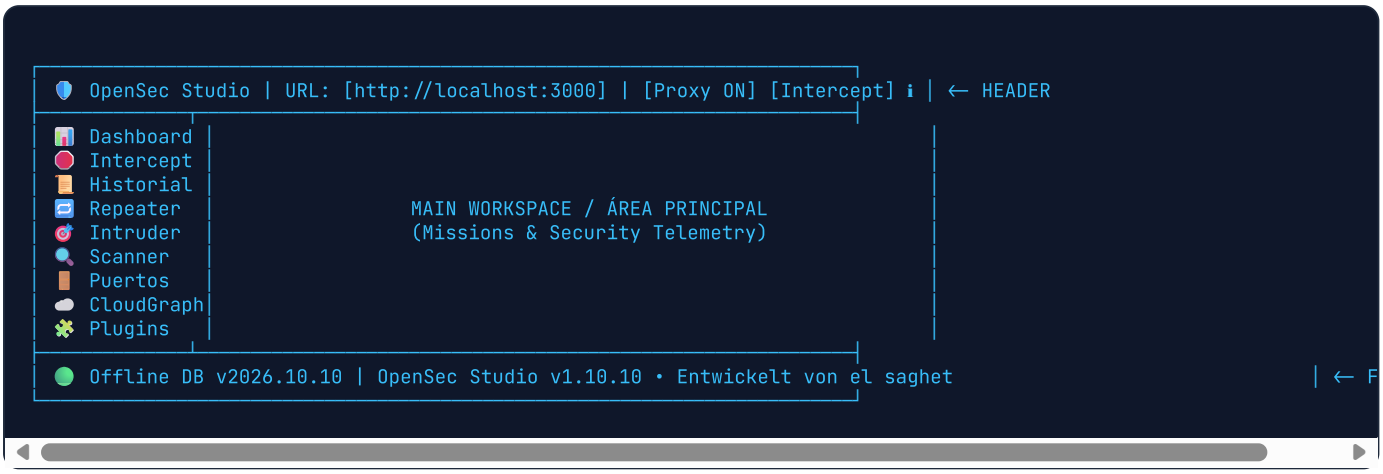
Es ist Ihr **magischer Detektiv-Rucksack**, erschaffen von **el saghet**. Darin tragen Sie Werkzeuge, um Briefe in der Luft abzufangen (Interceptor), zu kopieren (Repeater), Schlüssel zu testen (Intruder), Tore zu prüfen (Scanner) und über 1.200 Bedrohungen offline einzusehen.

> **🌟 Grundprinzip: 100% Real, Keine Simulationen**
>
> In OpenSec Studio ist keine Schaltfläche ein Platzhalter. Jede Aktion führt nativen Rust-Code aus und verarbeitet authentische Netzwerkpakete.

Kapitel 1: Erster Flug & Bildschirmanatomie

Doppelklicken Sie auf `OpenSec Studio.exe`. Das Fenster öffnet sich sofort hardwarebeschleunigt.

Visuelle Struktur der Benutzeroberfläche:



Bereich	Funktion in OpenSec Studio	Metapher zum Verständnis
1. Header (Oben)	Schnellsteuerung: Ziel-URL, Proxy Ein/Aus, Abfangen und Info (ℹ️).	Das Lenkrad und Armaturenbrett.
2. Sidebar (Menü)	Direkte Navigation zu allen 18 Modulen.	Ihr geordnetes Werkzeugregal.
3. Arbeitsbereich	Code-Editoren, Verkehrsübersichten und Berichte.	Ihre Werkbank im Labor.

🕵️ **Detektiv-Mission 1: Die offizielle Plakette**

Klicken Sie auf ℹ️ oben rechts. Sie sehen Version **v1.10.10** und die Autorenwürdigung für **el saghet**.

Kapitel 2: Das Dashboard-Kontrollzentrum

Echtzeit-Telemetrie und Sicherheitsstatus auf einen Blick.

> 🚗 **Tacho und Anzeigeinstrumente**
>
> Zeigt Geschwindigkeit, Motorstatus und Warnleuchten des Netzwerks.

Bereich	Funktion in OpenSec Studio	Metapher zum Verständnis
Gesamtanfragen	Zähler des analysierten Verkehrs.	Gefahrene Kilometer.
Kritische Lücken	Rote Alarmmeldung für dringende Fehler.	Motor-Warnleuchte.
Sicherheits-Score	Prozentuale Gesamtbewertung.	Gesamtzustand des Fahrzeugs.

> 🕵️ **Detektiv-Mission 2: Radar aktivieren**
>
> Schalten Sie den Proxy ein. Der Status wechselt zu leuchtend grünem "Aktiv".

Kapitel 3: Der Zollbeamte (HTTP-Interceptor & HTTPS-Tunnel)

Prüft Pakete zwischen Browser und Server vor der Übertragung.

> 🛑 **Der Zöllner mit dem Klemmbrett**
>
> Briefe werden vor dem Versand abgefangen, können editiert oder verworfen werden.

Bereich	Funktion in OpenSec Studio	Metapher zum Verständnis
Intercept ON / OFF	Aktiviert das Anhalten von Paketen.	Schranke senken oder heben.
Forward (Weiterleiten)	Sendet den bearbeiteten Brief ab.	Fahrzeug passieren lassen.
Drop (Verwerfen)	Bricht die Verbindung sofort ab.	Verdächtige Fracht beschlagnahmen.

> 🕵️ **Detektiv-Mission 3: Nachricht in der Luft ändern**
>
> Fangen Sie ein Formular ab, ändern Sie einen Wert und klicken Sie auf Weiterleiten.

Kapitel 4: Das Bordbuch (HTTP-Historie)

Unveränderliche Protokollierung aller übertragenen Anfragen.

> 📜 **Das Buch des königlichen Archivars**
>
> Jeder Brief wird mit Zeitstempel, Methode, Status und Größe festgehalten.

Bereich	Funktion in OpenSec Studio	Metapher zum Verständnis
200 OK (Grün)	Erfolgreich zugestellte Anfrage.	Reibungslose Lieferung.
404 / 403 (Gelb)	Seite fehlt oder Tür verschlossen.	Fehlende Adresse oder Sperrgebiet.
500 Fehler (Rot)	Serverfehler.	Brand im Lager des Ladens.

> 🕵️ **Detektiv-Mission 4: Sensiblen Verkehr filtern**
>
> Geben Sie "/api" in die Filtersuche ein, um Web-API-Endpunkte zu isolieren.

Kapitel 5: Der magische Kopierer (Nativer Rust-Repeater)

Sendet Anfragen über native Rust-Sockets mit präziser Latenzmessung.

> 🔁 **Der Klone-Automat**
>
> Ändern Sie einen Header oder Parameter und senden Sie ihn blitzschnell erneut ab.

Bereich	Funktion in OpenSec Studio	Metapher zum Verständnis
Multi-Tab-Ansicht	Paralleles Arbeiten an mehreren Anfragen.	Mehrere Dokumente auf dem Tisch.
Send-Button	Löst den Versand über die Rust-Engine aus.	Starttaste am Kopierer drücken.
Split-View	Anfrage links, Antwort rechts.	Vergleich zweier Briefe nebeneinander.

> 🕵️ **Detektiv-Mission 5: Header analysieren**
>
> Senden Sie eine Anfrage an einen Test-Endpunkt und prüfen Sie die Millisekunden-Reaktionszeit.

Kapitel 6: Der Schlüsseltest-Roboter (Intruder)

Automatisiertes Fuzzing und Wörterbuchangriffe mit hoher Durchsatzrate.

> **Der blitzschnelle Schlosser-Roboter**
>
> Testet 1.000 Schlüssel im Bruchteil einer Sekunde und zeigt, welcher das Schloss öffnet.

Bereich	Funktion in OpenSec Studio	Metapher zum Verständnis
Markierungen §payload§	Markiert Injektionspunkte in der Anfrage.	Kreuz an der Schlossöffnung zeichnen.
Sniper-Modus	Testet Positionen nacheinander.	Präziser Scharfschütze.
Cluster-Bomb	Testet alle Kombinationen von Benutzer und Passwort.	Jeder Schlüssel an jedem Schloss.

Detektiv-Mission 6: Versteckte Pfade aufdecken

Starten Sie einen Test mit Pfadlisten (admin, login) und achten Sie auf geänderte Antwortgrößen.

Kapitel 7: Der Live-Sicherheitsprüfer (DAST-Scanner & YAML)

Dynamische Sicherheitsanalyse nach OWASP Top 10, SQL-Injection und XSS.

> 🔍 **Der Detektiv mit Lupe und Block**
>
> Prüft Wände, Fenster und Schlösser auf Sicherheitslücken.

Bereich	Funktion in OpenSec Studio	Metapher zum Verständnis
Passiver Scan	Untersucht Header ohne aggressive Anfragen.	Vom Gehweg aus beobachten.
Aktiver Scan	Sendet gezielte Sicherheitspayloads.	Am Schloss rütteln.
SARIF-Export	Erzeugt Berichte nach Industriestandard.	Offizieller Prüfbericht.

🕵️ Detektiv-Mission 7: Sicherheits-Header prüfen

Starten Sie einen passiven Scan und prüfen Sie das Fehlen von CSP-Headern.

Kapitel 8: Der Türklinken-Prüfer & Schlosser (Portscan & SSH)

Scannt alle 65.535 TCP-Ports und auditiert Server nach CIS-Benchmarks.

> 🚪 **An alle Türen im Palast klopfen**
>
> Ermittelt, welche Türen offen sind (Port 80, 443, 22) und welcher Dienst dahinter lauscht.

Bereich	Funktion in OpenSec Studio	Metapher zum Verständnis
Asynchroner TCP-Scan	Schneller Portscan in Rust.	Ein Team klopft gleichzeitig an alle Türen.
SSH-Audit	Prüft Betriebssystemeinstellungen.	Den Tresorraum innen prüfen.

> 🕵️ **Detektiv-Mission 8: Offene Web-Ports finden**
>
> Scannen Sie Ports 80–8088 auf 127.0.0.1 und beobachten Sie gefundene Dienste.

Kapitel 9: Das magische Rezeptbuch (Nuclei-YAML-Vorlagen)

Erstellen Sie eigene Erkennungsregeln in deklarativem YAML-Format.

> 📜 **Das Zauberformel-Buch**
>
> Jede Vorlage ist ein Rezept: Welcher Request wird gesendet, welche Antwort zeigt Gefahr an.

Bereich	Funktion in OpenSec Studio	Metapher zum Verständnis
Live-Editor	Vorlagenerstellung mit Syntax-Prüfung.	Formeln mit Tinte notieren.
Matcher & Extraktoren	Regeln für Schlüsselwörter und Regex.	Die Zutat, die die Falle verrät.

> 🕵️ **Detektiv-Mission 9: Eigene Regel erstellen**
>
> Erstellen Sie eine Vorlage für offene /.git/HEAD Pfade im Live-Validator.

Kapitel 10: Der Universal-Übersetzer (Decoder)

Konvertiert Text zwischen Base64, URL-Encoding, Hexadezimal und Hashes.

> 🔑 **Der Rosetta-Stein der Detektive**
>
> Macht codierte Spionagenachrichten im Handumdrehen lesbar.

Bereich	Funktion in OpenSec Studio	Metapher zum Verständnis
URL-Encode	Sonderzeichen webkonform verpacken.	Briefpost sicher verpacken.
Base64 & Hex	Binärdaten in Klartext übersetzen.	Geheimschrift lesbar machen.
Hashes (SHA-256)	Einweg-Prüfsummen berechnen.	Der digitale Fingerabdruck.

🕵️ **Detektiv-Mission 10: Base64 entschlüsseln**

Fügen Sie Base64-Text ein und wählen Sie "Decode as Base64".

Kapitel 11: Der Materialprüfer (SCA-Abhängigkeiten)

Prüft package.json auf bekannte Schwachstellen in Bibliotheken.

> 🧱 **Der Bauprüfer für Steine und Träger**
>
> Erkennt, ob Baumaterialien Risse oder Herstellungsfehler aufweisen.

Bereich	Funktion in OpenSec Studio	Metapher zum Verständnis
CVE-Abgleich	Gleicht Versionen mit CVE-Datenbanken ab.	Material-Rückruflisten prüfen.
Empfehlungen	Nennt die sichere Mindestversion.	Anweisung zum Trägeraustausch.

> 🕵️ **Detektiv-Mission 11: package.json prüfen**
>
> Laden Sie ein Manifest und prüfen Sie gelistete Warnungen.

Kapitel 12: Die Schatzkarte (SiteMap & JS-Spider)

Hierarchischer Verzeichnisbaum aller Endpunkte und Skript-Pfade.

> 🗺️ **Die Landkarte des Königreichs**
>
> Zeichnet jede Straße und Hintertür auf, die beim Surfen entdeckt wird.

Bereich	Funktion in OpenSec Studio	Metapher zum Verständnis
Verzeichnisbaum	Strukturierte Übersicht nach Domain und Pfad.	Äste eines Stammbaums.
JS-Routen-Extraktor	Findet versteckte API-Routen im Client-Code.	Geheimgänge in Bauplänen finden.

> 🕵️ **Detektiv-Mission 12: Serverbaum erforschen**
>
> Surfen Sie mit aktivem Proxy und beobachten Sie den automatischen Aufbau der SiteMap.

Kapitel 13: Der Spionage-Briefträger (OAST Collaborator)

Erkennt blinde Schwachstellen (Blind SSRF, Log4Shell) über Out-of-Band-Signale.

> 🔔 **Die Falle mit der Glocke**
>
> Wird eine geheime Rückadresse aufgerufen, läutet die Glocke und bestätigt die Lücke.

Bereich	Funktion in OpenSec Studio	Metapher zum Verständnis
Domain-Generator	Einzigartige IDs zur Angriffskorrelation.	Seriennummer der Falle.
DNS/HTTP-Log	Zeigt Rückmeldungen des Zielservers an.	Die Alarmglocke schlägt an.

> 🕵️ **Detektiv-Mission 13: OAST-Falle auslegen**
>
> Generieren Sie eine Testadresse und beobachten Sie eingehende DNS-Signale.

Kapitel 14: Die Zeitmaschine & der Richter (Diffing & PCI-DSS)

Vergleicht Scan-Ergebnisse historisch und bewertet Konformität nach PCI-DSS v4.0.

> ⚖️ **Die Waagschale und die Zeitkapsel**
>
> Vergleicht gestern mit heute, um behobene Fehler zu loben und neue zu rügen.

Bereich	Funktion in OpenSec Studio	Metapher zum Verständnis
Schwachstellen-Diff	Kategorisiert in Behoben, Neu und Fortbestehend.	Erledigte und offene Aufgaben.
PCI-DSS v4.0	Prozentuale Einhaltung von Bankenstandards.	Die Prüfungsnote des Richters.

🕵️ **Detektiv-Mission 14: Zwei Scans vergleichen**

Laden Sie zwei Scans und prüfen Sie behobene Lücken in grünem Status.

Kapitel 15: Die große geheime Enzyklopädie (Offline CVE Feeds)

Offline-Katalog mit über 1.200 Bedrohungen, abrufbar in unter 5 Millisekunden.

> 📖 **Das geheime Lexikon im Rucksack**
>
> Funktioniert im Flugzeug oder im abgeschirmten Bunker ohne WLAN.

Bereich	Funktion in OpenSec Studio	Metapher zum Verständnis
Echtzeitsuche (<5ms)	Schneller Speicherindex.	Sofortiges Aufschlagen der richtigen Seite.
Delta-Synchronisation	Aktualisiert Signaturen bei Internetverbindung.	Der Bote mit neuen Bänden.

> 🕵️ **Detektiv-Mission 15: Berühmte Lücke suchen**
>
> Suchen Sie nach "Log4Shell" und lesen Sie Vektor und Lösungsvorschlag.

Kapitel 16: Der Missionssafe (.opensec-Projekte)

Verschlüsselt vollständige Untersuchungen mit AES-256-GCM und PBKDF2.

> 🔒 **Der gepanzerte Tresor des Detektivs**
>
> Sperrt Notizen, Repeater-Tabs und Daten vor fremden Blicken weg.

Bereich	Funktion in OpenSec Studio	Metapher zum Verständnis
Projekt speichern	Serialisiert den gesamten Arbeitsbereich.	Alles im Tresor verschließen.
AES-256-GCM	Höchste kryptografische Vertraulichkeit.	Das unknackbare Zahlenschloss.

> 🕵️ **Detektiv-Mission 16: Projekt verschlüsseln**
>
> Wählen Sie "Projekt speichern", vergeben Sie ein Passwort und prüfen Sie die Datei.

Kapitel 17: Der Erweiterungsladen (BApp Community Store)

Installieren und Verwalten von Community-Erweiterungen im JSON-Format.

> 🧩 **Der Zubehörladen für Detektive**
>
> Rüsten Sie Ihren Rucksack mit neuen Werkzeugen und Sensoren aus.

Bereich	Funktion in OpenSec Studio	Metapher zum Verständnis
1-Klick-Installation	Dynamische Aktivierung von Plugins.	Werkzeug am Gürtel befestigen.
Lokale Plugins laden	Eigene JSON-Erweiterungen importieren.	Eigenbau-Gadget verwenden.

> 🕵️ **Detektiv-Mission 17: Plugins erkunden**
>
> Öffnen Sie den Reiter Plugins und aktivieren Sie eine Erweiterung.

Kapitel 18: SSL-Zertifikate, 60 Tage Testphase, $30 BTC-Spende & Credits

X.509 Root CA für HTTPS, 60 Tage unbeschränkte Nutzung und Bitcoin-Zahlungsradar.

> 🛡️ **Der Vertrauenspass und die Ehrentafel**
>
> Das Zertifikat ist Ihr Diplomatenpass, der dem Browser Vertrauen signalisiert.

Bereich	Funktion in OpenSec Studio	Metapher zum Verständnis
CA-Root-Zertifikat	Installiert Vertrauen für HTTPS-Prüfung ohne Warnungen.	Das offizielle Siegelwachs.
60-Tage-Testphase	60 Tage unbeschränkter Zugang mit Multi-Anker-Persistenz.	Zweimonatiger Freipass für das Königreich.
30 USD Bitcoin-Spende	Unterstützung unabhängiger Software mit automatischem Radar.	Solidaritätsbeitrag zur Detektivgilde.
Autorenschaft	Gestaltet und programmiert von el saghet.	Die eingravierte Meistersignatur.

> 🕵️ **Detektiv-Mission 18: Die offizielle Ehrentafel**
>
> Öffnen Sie Über OpenSec Studio: Entwickelt von el saghet • Version v1.10.10 Offiziell 2026.

Kapitel 19: Die Cloud-Sternenkarte (CloudGraph: CNAPP, Wiz-Engine, DSPM & SIEM)

Ganzheitliche Cloud-Sicherheitsprüfung (CSPM, CIEM, CWPP, CDR, DSPM & IaC) nach dem Vorbild der Wiz-Architektur. Visualisiert den Cybersicherheitsgraphen, korreliert toxische Pfade und emuliert lokale Umgebungen mit LocalStack und Open-Source-Laboren.

> 🌠 **Die schwebende Wolkenstadt und das Radar für toxische Kombinationen**
>
> Stellen Sie sich vor, Ihr Unternehmen besitzt schwebende Festungen in verschiedenen Clouds. CloudGraph ist ein 3D-Radar, das jede Brücke und jeden Tresor kartiert. Statt Sie mit Einzelfehlern zu überfluten, alarmiert es gezielt bei der "perfekten Bedrohung": offene Pforte + verwundbarer Server + Generalschlüssel + vertrauliche Daten.

Topología y Grafo de Ataque Multidimensional (Wiz-like CNAPP):

```
┌──────────────────────────────────────────────────────────────────────────────┐
│ ☁️ CLOUDGRAPH | Proveedor: AWS Live [112233445566] | 4 Activos | 1 Ruta Crítica P1 │
├──────────────────────────────────────────────────────────────────────────────┤
│ 🔍 Quick Query: [[Todos]] [[🔥 Rutas P1]] [[🌐 Expuestos]] [[👑 IAM]] [[💾 PII]]  │
├──────────────────────────────────────────────────────────────────────────────┤
│ [🌐 Internet] ═(exploit)═> [💻 EC2 Proxy] ═(assume)═> [🔑 IAM Roller] ═(read)═> [💾 S3 Vault] │
│      (0.0.0.0/0)             (SSRF IMDSv1)            (Full Admin)          (Tarjetas PCI)  │
├──────────────────────────────────────────────────────────────────────────────┤
│ [Grafo] [Tóxicos (1)] [Inventario] [CIEM] [SIEM Hub] [IaC] [CDR] [CWPP] [💾 DSPM (4)] │
├──────────────────────────────────────────────────────────────────────────────┤
│ 🚨 Alerta P1: Internet ➔ EC2 (CVE-2024-SSRF) ➔ Rol IAM ➔ S3 PII Financiera (KMS None) │
│ 🛡️ Playbook SOAR: [🔒 Bloquear Acceso Público S3] [Desvincular Rol] [KMS KMS-CMK]  │
└──────────────────────────────────────────────────────────────────────────────┘
```

Bereich	Funktion in OpenSec Studio	Metapher zum Verständnis
CyberGraph & Schnellabfragen	Interaktive Angriffsgraph-Leinwand mit Schnellfiltern: [🔥 Kritische P1-Pfade], [🌐 Exponiert + CVEs], [👑 Admin-IAM] und [💾 PII-Speicher].	Das Wärmebildteleskop, das Infiltrationskorridore sichtbar macht.
Toxische Kombinationen	Wiz-Core-Korrelation von Internet-Exposition, CVEs, übermäßigen IAM-Rechten und sensiblen Daten.	Die Anatomie eines Einbruchs: offene Tür + defektes Schloss + Generalschlüssel.
CIEM & IAM-Rechteüberprüfung	Erkennung überprivilegierter Identitäten und Privilegienerweiterungspfade.	Entdecken, dass der Schlosslehrling den Hauptschlüssel zum Thronsaal besitzt.
DSPM & Datensicherheit	Klassifizierung von Kreditkarten (PCI), Ausweisen (PII) und Gesundheitsdaten in S3, Blob und RDS mit 1-Klick-KMS-SOAR.	Die Zollstelle, die Goldkisten identifiziert und KMS-Schlösser erzwingt.
CWPP & Container-Sicherheit	Agentenlose Prüfung von Container-Registries (ECR, ACR, GAR), Erkennung eingebetteter Geheimnisse und OPA-Gatekeeper-Quarantäne.	Überprüfung von Frachtcontainern vor dem Verladen ins Schiff.
CDR & MITRE ATT&CK for Cloud	Echtzeit-Erkennung von Angreifertaktiken in CloudTrail- und Azure-Aktivitätsprotokollen.	Infrarotkameras, die nächtliche Eindringlinge auf frischer Tat

Bereich	Funktion in OpenSec Studio	Metapher zum Verständnis
		ertappen.
IaC Shift-Left-Prüfung	Vorabprüfung von Terraform-Plänen (JSON) und Kubernetes-Manifesten (YAML) vor dem Rollout.	Baupläne prüfen und Mängel beheben, bevor das Fundament gegossen wird.
Lokale Emulatoren & Labore (Optionen 2 & 4)	Anbindung an LocalStack (localhost:4566), Minikube und 1-Klick-Laden von OWASP CloudGoat, Terragoat und DVKS.	Der Truppenübungsplatz zum kostenlosen Training ohne scharfe Munition.
SIEM-Hub (Sentinel / Splunk)	Automatisierte Alarmübertragung und Abfrageerstellung in Sentinel KQL und Splunk SPL.	Das rote Krisentelefon zur Sicherheitszentrale.

🕵️ **Detektiv-Mission 19: Ein verwundbares Cloud-Labor mit 1 Klick prüfen**

Öffnen Sie CloudGraph, klicken Sie auf "Cloud / IaC verbinden", wählen Sie "Labs", drücken Sie " ⚡ Testdaten / Lab laden" und beobachten Sie den P1-Angriffspfad im Graphen.